

STRATUM CAPITAL BANK

Enterprise Governance & Risk Framework

CHAPTER 8

Enterprise Audit, Monitoring & Continuous Compliance Framework

Document Reference	SCB-EGRF-CH8-v5.4.1
Version	5.4.1
Classification	Confidential – Internal Use Only
Effective Date	1 January 2025
Next Review Date	31 December 2025
Document Owner	Chief Audit Executive
Approved By	Board Audit Committee
Status	Active

CONFIDENTIAL – INTERNAL USE ONLY

This document contains proprietary and confidential information of Stratum Capital Bank. Unauthorised disclosure, reproduction, or distribution is strictly prohibited. Recipients are bound by the Bank's Information Security Policy and applicable confidentiality obligations.

8.1 Purpose of Internal Audit

8.1.1 Objectives

Internal Audit at Stratum Capital Bank (hereinafter 'the Bank') exists to provide the Board of Directors, the Board Audit Committee, and Senior Management with independent, objective assurance and advisory services designed to add value and improve the Bank's operations. The function assists the Bank in accomplishing its strategic and operational objectives by bringing a systematic and disciplined approach to the evaluation and improvement of the effectiveness of risk management, internal control, and governance processes.

Internal Audit's primary objectives are as follows. First, to evaluate the adequacy and effectiveness of the Bank's internal control framework in mitigating identified and emerging risks to an acceptable level within the Board-approved risk appetite. Second, to assess the quality and reliability of financial, operational, and management information used in decision-making, including information generated by automated systems and artificial intelligence models. Third, to verify compliance with applicable laws, regulations, regulatory guidance, and internal policies, including but not limited to the requirements of the Prudential Regulation Authority, the Financial Conduct Authority, the Bank of England, and all applicable anti-money laundering and counter-terrorist financing legislation. Fourth, to evaluate the efficiency and effectiveness of the Bank's operations and the extent to which resources are used economically and in alignment with the Board's strategic objectives. Fifth, to identify fraud risks, control failures, and operational deficiencies, and to communicate findings with sufficient clarity, accuracy, and urgency to enable timely management action. Sixth, to provide forward-looking advisory insight on emerging risks, control design weaknesses, and governance gaps, particularly in relation to technology, data, artificial intelligence, and third-party risk.

8.1.2 Independence and Objectivity

The Internal Audit function shall at all times maintain its organisational independence, functional independence, and individual objectivity. Organisational independence is preserved through the Chief Audit Executive's (CAE) direct reporting line to the Board Audit Committee and administrative reporting to the Chief Executive Officer. The CAE shall have the unrestricted authority to communicate directly and privately with the Board Audit Committee Chair at any time, without the involvement of Executive Management.

Individual auditors shall be free from any condition that threatens their ability to carry out audit responsibilities in an impartial manner. All members of the Internal Audit function shall complete an annual independence declaration, disclosing any financial interests, personal relationships, or prior operational involvement that could impair or be perceived to impair their objectivity. Where an actual or potential impairment of independence is identified, the affected auditor shall be removed from the relevant engagement and the matter shall be disclosed to the CAE and, where material, to the Board Audit Committee.

Internal Audit staff shall not assume operational responsibilities or perform any function that they may reasonably be required to audit within a period of no less than twelve months. The Bank shall maintain a documented 'cooling off' register recording all instances of auditors transitioning to or from operational roles, and this register shall be reviewed by the Board Audit Committee on a semi-annual basis.

8.1.3 Three Lines of Defence Model

The Bank operates a Three Lines of Defence model as the overarching framework for managing risk and maintaining effective internal control. This model defines roles, responsibilities, and accountabilities across the organisation and ensures that risks are identified, assessed, managed, and reported through clearly segregated functions.

First Line of Defence — Business Units and Risk Owners

The First Line comprises all business units, functions, and individuals who own and manage risk on a day-to-day basis. Front-line staff and their management are directly responsible for implementing controls, identifying risk events, and maintaining compliance with applicable policies and regulations. First Line personnel are required to operate within the risk appetite set by the Board, to maintain adequate records of control activities, and to escalate issues promptly through established governance channels.

Second Line of Defence — Risk Management and Compliance

The Second Line comprises the Enterprise Risk Management function, the Compliance function, and specialist oversight functions including Financial Crime, Data Privacy, and Model Risk Management. The Second Line is responsible for establishing and maintaining the Bank's risk management framework, setting policy and standards, providing expert guidance to the First Line, and independently monitoring and testing First Line adherence to established controls. Second Line functions report functionally to the Chief Risk Officer and shall maintain an arm's-length relationship with the business units they oversee.

Third Line of Defence — Internal Audit

The Third Line is Internal Audit, which provides the Board and Senior Management with independent assurance over the adequacy and effectiveness of governance, risk management, and internal control processes across both the First and Second Lines. Internal Audit is not responsible for designing, implementing, or operating controls; its role is to objectively evaluate whether those controls are functioning as intended. Internal Audit reports independently to the Board Audit Committee and shall have no authority over, and shall not be directed by, the functions it audits.

8.1.4 Assurance Responsibilities

Internal Audit is the primary source of independent, objective assurance for the Board and Board Audit Committee regarding the effectiveness of the Bank's control environment. Assurance provided by Internal Audit encompasses, but is not limited to, the following dimensions: the design adequacy of controls; the operating effectiveness of controls in practice; the accuracy and completeness of risk reporting; the quality of the Bank's risk identification and assessment processes; the integrity of financial and regulatory reporting; the compliance posture of the Bank with respect to applicable legal and regulatory obligations; and the governance arrangements for significant risk categories including credit risk, market risk, liquidity risk, operational risk, technology risk, conduct risk, and financial crime risk.

Internal Audit shall coordinate its assurance activities with the Second Line functions to minimise duplication of effort and to ensure that assurance coverage is comprehensive and proportionate. An Assurance Map shall be maintained by the CAE, updated at least annually, which documents all sources of assurance across the Bank's risk universe and identifies any assurance gaps or overlaps requiring attention.

8.2 Audit Governance

8.2.1 Internal Audit Function

The Internal Audit function is a permanent, independent function of the Bank with a mandate established in the Internal Audit Charter, which is approved by the Board Audit Committee and reviewed at least annually. The Charter defines the purpose, authority, scope of work, and reporting obligations of Internal Audit, and grants the function unconditional access to all records, personnel, physical premises, systems, data, and information held by or on behalf of the Bank. The Charter shall be accessible to all employees and shall be published on the Bank's intranet governance portal.

The Internal Audit function shall be adequately resourced with qualified professionals possessing the necessary skills, experience, and professional certifications commensurate with the scope and complexity of the Bank's activities. The staffing model shall be reviewed annually to ensure that the function can execute its approved Audit Plan without compromising quality or independence. Where specialist skills are required on a temporary basis, co-sourced or outsourced audit resources may be engaged, subject to appropriate conflict checks and oversight by the CAE.

8.2.2 Chief Audit Executive

The Chief Audit Executive (CAE) holds ultimate accountability for the effective management, operation, and quality assurance of the Internal Audit function. The CAE shall be appointed by, and shall serve at the pleasure of, the Board Audit Committee. The remuneration of the CAE shall be determined by the Remuneration Committee in consultation with the Board Audit Committee, to prevent undue Executive Management influence over the compensation structure of the CAE.

The CAE's responsibilities include: developing and obtaining approval for the Annual Audit Plan; presenting audit findings and status reports to the Board Audit Committee at each scheduled meeting; providing an annual opinion on the overall adequacy and effectiveness of the Bank's risk management, control, and governance processes; managing the Internal Audit budget and resource allocation; maintaining the Internal Audit Charter and Methodology; liaising with external auditors and regulatory bodies; and overseeing the professional development of all Internal Audit staff.

8.2.3 Board Audit Committee

The Board Audit Committee (BAC) exercises oversight of the Internal Audit function on behalf of the full Board of Directors and is the primary governance body to which Internal Audit reports. The BAC is constituted in accordance with the Bank's Articles of Association and relevant regulatory requirements, and shall comprise no fewer than three Non-Executive Directors, the majority of whom shall be independent, with at least one member possessing recent and relevant financial expertise as defined by applicable regulatory guidance.

The BAC's responsibilities in relation to Internal Audit include: approving the Internal Audit Charter; approving the Annual Audit Plan, including any material in-year changes; reviewing and challenging audit findings, management responses, and remediation progress; evaluating the performance and independence of the CAE; reviewing the results of the Internal Audit Quality Assurance Programme; considering the adequacy of Internal Audit resources; and receiving and considering all reports from Internal Audit designated as Critical or requiring escalation.

8.2.4 Risk Committee

The Board Risk Committee (BRC) receives audit reports relevant to the Bank's risk appetite, risk management effectiveness, and the robustness of the Enterprise Risk Management framework. The CAE or a nominated senior representative of Internal Audit shall attend BRC meetings as an observer and shall present to the BRC on matters within the audit plan or arising from audit work that are relevant to the Bank's risk profile. The BRC and BAC shall maintain coordination protocols to ensure that risk-related audit findings are appropriately shared and that the risk appetite implications of significant audit findings are considered at Board level.

8.2.5 Compliance Function

The Compliance function, operating as part of the Second Line of Defence, shall cooperate fully with Internal Audit and shall provide access to all monitoring reports, regulatory correspondence, compliance testing results, and policy documentation as requested. Compliance shall not direct the activities of Internal Audit; however, Internal Audit shall consider the outputs of Compliance monitoring programmes in scoping and planning audit engagements to maximise efficiency and avoid undue duplication. Significant compliance findings shall be shared with the CAE promptly upon identification, and Internal Audit shall assess whether those findings warrant an unplanned or expedited audit engagement.

8.2.6 Business Units

All business units and functions of the Bank are subject to audit in accordance with the Annual Audit Plan and any unplanned reviews initiated by the CAE. Business unit heads and their staff are required to cooperate fully and promptly with all audit requests, to provide accurate and complete information, and to refrain from any action intended to delay, impede, or influence the outcome of an audit engagement. Audit management is required to notify the relevant business unit head prior to commencement of an audit engagement, setting out the proposed scope, timing, and resource requirements. Business unit management shall be given the opportunity to review draft findings and to provide a formal management response prior to finalisation of the audit report.

8.2.7 External Auditors

The Bank's external auditors are appointed by the Board on the recommendation of the Board Audit Committee and are independent of the Bank in accordance with applicable professional and regulatory standards. Internal Audit shall maintain a constructive and professional relationship with the external audit engagement team, coordinating on the annual audit plan, sharing work papers where appropriate, and avoiding unnecessary duplication of effort. The CAE shall meet with the external audit lead partner no less than twice annually to discuss areas of mutual interest and to explore opportunities for reliance on Internal Audit work. Reliance by external auditors on Internal Audit work is subject to their independent professional judgement and is not a requirement of this Framework.

8.3 Risk-Based Audit Planning

8.3.1 Annual Audit Plan

The Annual Audit Plan (AAP) is the primary planning instrument for Internal Audit activities. The CAE shall develop the AAP each year through a structured risk-based planning process, commencing no later than the third quarter of the preceding financial year. The AAP shall reflect the Bank's risk universe, the Board-approved risk appetite, the outputs of the Risk Assessment Methodology described in Section 8.3.3, regulatory expectations, and the cumulative results of prior audit engagements.

The AAP shall specify, for each planned audit engagement: the audit entity or subject; the proposed audit type; the planned start and completion dates; the estimated resource allocation in audit days; the primary audit objectives and scope; and the relative risk rating assigned through the planning process. The AAP shall include a reserve allocation of not less than ten percent of total available audit days to accommodate unplanned reviews, regulatory requests, and investigation support.

The AAP shall be presented to, and approved by, the Board Audit Committee prior to the commencement of the financial year to which it relates. Any material in-year amendments to the AAP, including the addition or removal of planned engagements or material changes to resource allocation, shall require BAC approval. The CAE shall report AAP progress to the BAC at each scheduled meeting, including explanations of any variances against plan.

8.3.2 Quarterly Reviews

At the conclusion of each calendar quarter, the CAE shall conduct a formal quarterly review of the AAP to assess progress against planned activities, identify any emerging risks or changes in the risk environment that may require plan adjustment, and prioritise any unplanned reviews. The results of the quarterly review shall be documented and presented to the BAC at the next scheduled meeting. Where a quarterly review identifies a material change in the risk profile that necessitates a significant re-prioritisation of audit resources, the CAE shall seek expedited BAC guidance.

8.3.3 Risk Assessment Methodology

The planning risk assessment is the analytical foundation upon which the AAP is constructed. The methodology employs a multi-factor risk scoring model that assesses each auditable entity within the Bank's risk universe across the following dimensions: inherent risk (including strategic, financial, operational, compliance, reputational, and systemic risk factors); control environment quality (based on the results of prior audits and Second Line assessments); management quality and risk culture; regulatory sensitivity and scrutiny; and the time elapsed since the last audit engagement.

Each auditable entity is assigned a composite risk score, which determines the frequency and intensity of audit coverage. Entities rated as High Risk shall be subject to audit no less frequently than annually. Entities rated as Medium Risk shall be subject to audit on a cycle not exceeding twenty-four months. Entities rated as Low Risk shall be subject to audit on a cycle not exceeding thirty-six months, or more frequently if circumstances warrant. The risk scoring methodology, weighting factors, and scoring results shall be documented and retained as working paper evidence for each AAP cycle.

8.3.4 High-Risk Areas

The following areas have been identified as inherently high risk and shall receive priority audit coverage under the AAP. These designations reflect the Bank's risk profile, regulatory environment, and historical loss experience, and shall be reviewed and confirmed or updated as part of each annual planning cycle: Treasury and Capital Markets; Credit Underwriting and Approvals; Anti-Money Laundering and Sanctions Compliance; Cybersecurity and Information Security; Artificial Intelligence and Model Risk; Regulatory Capital Reporting; Consumer Credit and Collections; Third-Party and Outsourcing Risk; Financial Reporting and Month-End Close; and Liquidity Risk Management.

8.3.5 Low-Risk Areas

Areas classified as Low Risk under the current risk assessment shall receive audit coverage on an extended cycle commensurate with their risk profile. Even for low-risk entities, audit coverage shall be maintained at a minimum frequency to ensure that the Internal Audit function retains adequate familiarity with the control environment and does not allow assurance gaps to develop. Low-risk designations shall be documented with supporting rationale and shall be reviewed if there is any material change in the entity's risk profile, organisational structure, or regulatory environment.

8.3.6 Emerging Risk Reviews

The dynamic and rapidly evolving nature of the financial services sector requires Internal Audit to maintain awareness of, and responsiveness to, emerging risks that may not yet be captured in the established risk universe. The CAE shall maintain an Emerging Risk Register, updated quarterly, which documents newly identified or evolving risk themes that may have implications for the Bank's control environment. Emerging risks identified through regulatory communications, industry forums, peer benchmarking, or the Bank's own risk management processes shall be assessed for potential inclusion in the AAP, either as standalone reviews or as additional scope elements within planned engagements.

8.3.7 AI Model Reviews

In recognition of the Bank's increasing reliance on artificial intelligence and machine learning models in credit decisioning, fraud detection, customer analytics, and operational processes, the AAP shall include dedicated AI model audit activities as described in Section 8.11 of this Chapter. AI model reviews shall be conducted by auditors with appropriate technical competency and, where necessary, shall be supplemented by specialist co-sourced resources. The frequency of AI model reviews shall reflect the materiality and complexity of the model, the volume of decisions it influences, and the residual risk identified in the most recent model validation.

8.3.8 Cyber Reviews

Cybersecurity represents a systemic and continuously evolving risk to the Bank's operations, data, and customer trust. The AAP shall include a programme of cybersecurity audit activities covering the technical security control environment, information security governance, incident response capabilities, third-party security risk, and regulatory compliance with applicable cybersecurity standards. Cyber reviews shall be conducted by or with the involvement of certified cybersecurity professionals and shall consider threat intelligence relevant to the financial services sector.

8.3.9 Credit Reviews

Credit risk is the most significant financial risk category for the Bank. The AAP shall include a regular programme of credit portfolio reviews, credit process audits, and credit model audits. Credit reviews shall assess the quality and consistency of credit underwriting, the appropriateness of risk grade assignments, the adequacy of provisioning, and the effectiveness of credit monitoring and collections processes. Credit review findings shall be reported to both the BAC and the Board Credit Committee.

8.3.10 AML Reviews

Anti-money laundering, counter-terrorist financing, and sanctions compliance represent areas of acute regulatory sensitivity and significant legal and reputational risk. The AAP shall include at minimum an annual comprehensive review of the Bank's AML/CTF and sanctions compliance programme, encompassing customer due diligence, enhanced due diligence, transaction monitoring, suspicious activity reporting, sanctions screening, and governance arrangements. AML audit findings shall be treated with heightened sensitivity and shall be reported to the BAC, the Board Financial Crime Committee (or equivalent), and, where required by law, to the relevant law enforcement or regulatory body.

8.4 Audit Types

8.4.1 Overview

Internal Audit at Stratum Capital Bank deploys a variety of audit types, each suited to a specific risk domain, objective, or audit context. The type of audit engagement to be applied to a given subject shall be determined during the planning phase, based on the nature of the risks involved, the regulatory context, and the most appropriate methodology for delivering meaningful assurance. The following audit types are recognised under this Framework.

8.4.2 Operational Audit

Operational audits assess the efficiency, effectiveness, and reliability of the Bank's business processes and operational controls. They examine whether processes are designed and operating in a manner that achieves the Bank's operational objectives, minimises wastage of resources, and produces reliable outputs. Operational audits may encompass end-to-end process reviews, transactional testing, process mapping and gap analysis, and evaluation of key performance indicators against targets.

8.4.3 Financial Audit

Financial audits focus on the accuracy, completeness, and integrity of the Bank's financial records, accounts, and financial reporting processes. They assess the adequacy of controls over the financial close process, the reliability of management accounts and regulatory returns, and compliance with applicable accounting standards and reporting requirements. Financial audits shall be coordinated with the external audit programme to promote efficiency and avoid duplication.

8.4.4 Compliance Audit

Compliance audits assess the Bank's adherence to applicable laws, regulations, regulatory guidance, and internal policies. They examine whether the Bank has implemented adequate controls to ensure compliance, whether those controls are operating effectively, and whether there are any actual or potential compliance failures requiring remediation. Compliance audits shall be conducted in close coordination with the Compliance function and shall consider any regulatory findings, correspondence, or thematic reviews relevant to the subject matter.

8.4.5 Credit Audit

Credit audits examine the Bank's credit risk management processes, including credit strategy, underwriting standards, credit approval processes, portfolio quality, credit grading accuracy, provisioning adequacy, and credit monitoring and recovery. Credit audits may cover retail, commercial, and wholesale credit portfolios, and shall include review of a representative sample of individual credit files to assess the quality of credit decisions and the completeness of credit documentation.

8.4.6 Technology Audit

Technology audits assess the adequacy and effectiveness of the Bank's IT governance, IT risk management, and IT controls. They cover areas including systems development and change management, IT operations and infrastructure, IT asset management, data management, business continuity and disaster recovery, and IT vendor management. Technology audits shall be conducted by auditors with appropriate technical qualifications and shall consider relevant industry frameworks including COBIT and ISO/IEC 27001.

8.4.7 Cyber Security Audit

Cybersecurity audits are a specialised subset of technology audits focusing on the Bank's defences against cyber threats. They assess the design and operating effectiveness of cybersecurity controls including network security, endpoint protection, identity and access management, vulnerability management, security monitoring and detection, incident response, and security awareness training. Findings from cybersecurity audits shall be treated as sensitive and distributed only to those with a clear need to know.

8.4.8 AI Governance Audit

AI governance audits assess the adequacy of the Bank's governance arrangements for the development, validation, deployment, monitoring, and retirement of AI and machine learning models. As detailed in Section 8.11, these audits encompass model risk management, explainability, fairness and bias testing, performance monitoring, and regulatory compliance. AI governance audits recognise that inadequately governed AI models can give rise to significant credit, operational, conduct, reputational, and legal risks.

8.4.9 Data Governance Audit

Data governance audits assess whether the Bank's data assets are managed in accordance with the Bank's Data Governance Framework, applicable data protection legislation, and regulatory expectations. They examine data quality, data lineage, data classification, access controls, and the adequacy of data management policies and standards. Given the increasing reliance of the Bank on data-driven decision-making and regulatory reporting, data governance audits are accorded a high priority in the AAP.

8.4.10 Vendor Audit

Vendor audits assess the risk management and control arrangements in place at material third-party service providers and outsourced service providers. They assess vendor performance against contractual obligations, the adequacy of the vendor's own control environment, and the extent to which the Bank is exposed to concentration, operational, or financial risk arising from the vendor relationship. Vendor audits shall be conducted in accordance with the Bank's Third-Party Risk Management Policy and shall consider the criticality and systemic importance of the service being provided.

8.4.11 Branch Audit

Branch audits are conducted across the Bank's branch network to assess compliance with operational procedures, cash handling controls, customer due diligence requirements, and local regulatory obligations. Branch audits may be announced or unannounced, and shall include physical inspection of the branch premises, review of transaction records, and assessment of staff adherence to policy. Unannounced branch audits shall be conducted where there is an identified risk of control circumvention.

8.4.12 Process Audit

Process audits examine specific operational or administrative processes end-to-end, with a view to identifying control gaps, inefficiencies, or compliance risks. Process audits may be conducted as standalone engagements or as a component of broader operational or compliance audits. They typically involve process mapping, walkthrough testing, and gap analysis against policy requirements and best practice.

8.4.13 Fraud Investigation Audit

Fraud investigation audits are conducted in response to allegations, suspicions, or confirmed instances of fraud, misconduct, or dishonesty involving Bank employees, customers, or third parties. These engagements require heightened confidentiality, strict evidence handling protocols, and close coordination with the Bank's Legal, HR, and Compliance functions. Findings from fraud investigation audits shall be reported directly to the CAE and, where warranted, to the BAC. Internal Audit's role in fraud investigations is fact-finding and evidence gathering; disciplinary and legal action shall be the responsibility of the appropriate functions.

8.4.14 Special Investigation

Special investigations are initiated at the direction of the Board Audit Committee, the Chief Executive Officer, or the CAE in response to specific concerns, regulatory requests, or identified control failures that fall outside the scope of the regular audit programme. Special investigations may address whistleblower allegations, suspected regulatory breaches, significant operational failures, or governance concerns. Resources for special investigations shall be drawn from the AAP reserve allocation and, if necessary, augmented through co-sourcing.

8.4.15 Regulatory Audit

Regulatory audits are conducted to assess the Bank's compliance with specific regulatory requirements, regulatory guidance, or supervisory expectations communicated by the relevant regulatory authority. They may be initiated in anticipation of, or in response to, regulatory examinations, and shall produce documentation and evidence suitable for presentation to regulators. Findings from regulatory audits shall be escalated in accordance with the regulatory sensitivity of the subject matter.

8.5 Continuous Monitoring Framework

8.5.1 Purpose and Rationale

Periodic audit engagements alone cannot provide the Board and Senior Management with the timely, dynamic visibility of the control environment required to manage risk effectively in a complex financial institution. The Bank's Continuous Monitoring Framework (CMF) supplements the periodic audit programme with automated, real-time, and near-real-time monitoring of key risk indicators, control performance metrics, and exception conditions, enabling early identification of emerging control weaknesses and compliance breaches before they escalate into material failures.

8.5.2 Key Risk Indicators

Key Risk Indicators (KRIs) are quantitative metrics that provide leading or concurrent signals of changes in the Bank's risk profile. The Bank maintains a KRI library, owned by Enterprise Risk Management and endorsed by Internal Audit, which spans all material risk categories within the Bank's risk taxonomy. KRIs shall have clearly defined thresholds aligned to the Board's risk appetite: a Green threshold indicating normal operating conditions; an Amber threshold indicating an elevated risk level requiring increased management attention; and a Red threshold indicating a breach of risk appetite requiring immediate escalation and management action.

Internal Audit shall independently review the design and appropriateness of KRIs on an annual basis, and shall assess whether the thresholds established are sufficiently sensitive to provide meaningful early warning without generating excessive false positives. KRI reporting shall be included in the Executive Risk Dashboard and presented to the Board Risk Committee at each scheduled meeting.

8.5.3 Key Performance Indicators

Key Performance Indicators (KPIs) measure the effectiveness and efficiency of operational processes and control functions relative to established targets. Internal Audit monitors KPIs for critical control functions including Compliance, Risk Management, IT Operations, and Credit. Sustained underperformance against KPI targets may indicate control weaknesses or resource constraints requiring audit attention and shall be documented as an input to risk-based audit planning.

8.5.4 Automated Monitoring

The Bank deploys automated monitoring tools and scripts across critical systems to continuously test the operation of key controls, identify anomalous transactions or system behaviours, and generate exception reports. Automated monitoring is applied to, among other areas: payment transaction screening; user access rights and privileged access; system configuration changes; credit exposure breaches; AML transaction monitoring alerts; and model output monitoring. The design, configuration, and maintenance of automated monitoring tools shall be subject to periodic audit review to ensure that they remain effective and fit for purpose.

8.5.5 Exception Monitoring

Exception monitoring identifies instances where a transaction, event, or condition falls outside defined parameters and may indicate a control failure, policy breach, or unusual risk. Internal Audit shall review exception reports generated by business units and Second Line functions on a regular basis to assess whether exceptions are being identified, investigated, and resolved in a timely and appropriate manner. Systemic patterns in exceptions shall be escalated to the CAE and may trigger an unplanned audit engagement.

8.5.6 Threshold Monitoring

Threshold monitoring applies defined quantitative limits to risk exposures, operational metrics, and compliance indicators, and generates automated alerts when those limits are approached or breached. Thresholds are calibrated to the Bank's risk appetite and are subject to periodic review to ensure they remain appropriate as the risk environment evolves. Internal Audit shall assess the adequacy of threshold-setting processes and shall review the Bank's response to threshold breaches as part of its monitoring and audit programme.

8.5.7 Real-Time Alerts

For certain critical risk categories, including cybersecurity incidents, significant fraud events, and major operational failures, the Bank operates real-time alert systems that notify designated personnel immediately upon detection of a defined trigger event. Internal Audit shall have read access to real-time alert logs and shall review the adequacy and timeliness of the Bank's response to alerts as part of its monitoring activities. The effectiveness of real-time alert systems shall be subject to periodic independent testing.

8.5.8 Dashboard Monitoring

The Bank maintains a suite of management dashboards that aggregate KRI, KPI, exception, and threshold monitoring data into accessible, visual formats for use by Senior Management, risk owners, and governance committees. Internal Audit shall participate in the governance of dashboard design and content to ensure that dashboards provide an accurate and balanced view of the risk and control environment and do not obscure unfavourable information. Dashboard outputs shall be available to Internal Audit as a continuous monitoring input.

8.5.9 Trend Analysis

Trend analysis involves the examination of monitoring data over time to identify directional movements in risk indicators, control performance, or compliance metrics that may not be apparent from point-in-time assessments. Internal Audit shall incorporate trend analysis into its continuous monitoring activities and its audit engagement planning, giving particular attention to adverse trends that may indicate systematic or structural control weaknesses. Trend analysis findings shall be incorporated into the CAE's regular reports to the BAC.

8.6 Regulatory Compliance Monitoring

8.6.1 Anti-Money Laundering and Counter-Terrorist Financing

The Bank operates under extensive AML and CTF regulatory obligations, the breach of which could give rise to severe regulatory, financial, and reputational consequences. Compliance monitoring of the AML/CTF programme encompasses the effectiveness of customer risk classification, the quality and timeliness of customer due diligence and enhanced due diligence, the performance of the transaction monitoring system including alert generation, alert investigation, and escalation quality, the completeness and accuracy of Suspicious Activity Reports submitted to the National Crime Agency, and the governance arrangements of the Money Laundering Reporting Officer function. Internal Audit shall conduct independent reviews of AML/CTF compliance monitoring activities to ensure that they are providing adequate assurance and that deficiencies identified are being appropriately remediated.

8.6.2 Know Your Customer

KYC compliance monitoring covers the completeness, currency, and accuracy of customer identification and verification records across all customer segments and product lines. The Bank is required to ensure that customer records are refreshed at periodic intervals commensurate with the customer's risk classification, and that any changes in a customer's risk profile are reflected in the customer's due diligence record in a timely manner. Compliance monitoring shall track the proportion of customer records that are overdue for refresh, the quality of KYC documentation, and compliance with the Bank's Onboarding Policy.

8.6.3 Consumer Protection

Consumer protection compliance monitoring encompasses adherence to applicable consumer credit legislation, responsible lending requirements, complaint handling obligations, product suitability requirements, and the Consumer Duty framework as implemented under FCA guidance. Monitoring shall include assessment of complaint volumes and root causes, outcomes testing to verify that customers are receiving fair outcomes, review of sales and advisory processes, and assessment of the adequacy and clarity of customer communications. Internal Audit shall provide assurance over the effectiveness of consumer protection compliance monitoring on a periodic basis.

8.6.4 Privacy and Data Protection Laws

The Bank is subject to the UK General Data Protection Regulation and the Data Protection Act 2018, and compliance with these instruments is a priority regulatory obligation. Compliance monitoring covers data subject rights fulfilment, lawful basis documentation, data breach identification and notification, privacy impact assessments for new processing activities, data transfer mechanisms for cross-border transfers, and vendor data processing agreements. Internal Audit shall review the adequacy of data protection compliance monitoring and shall independently assess the Bank's compliance with key GDPR obligations on a periodic basis.

8.6.5 Banking Regulations

Compliance monitoring encompasses adherence to all applicable prudential, conduct, and reporting regulations, including the Capital Requirements Regulation, the Payment Services Regulations, the Markets in Financial Instruments Directive as onshored into UK law, and all applicable regulatory technical standards and supervisory guidelines. Compliance monitoring shall track the Bank's compliance with regulatory reporting deadlines, the accuracy of regulatory returns, and the status of any open regulatory findings or requirements. Internal Audit shall review compliance monitoring coverage of banking regulations and shall assess whether any regulatory changes are being implemented on a timely basis.

8.6.6 Internal Policy Compliance

In addition to external regulatory requirements, Internal Audit monitors compliance with the Bank's own internal policies, standards, and procedures. Internal policy compliance monitoring shall assess whether business units are operating within approved policy parameters, whether policy exceptions have been properly approved and documented, and whether policy breaches have been identified, reported, and remediated. The Policy Management

function shall maintain a register of all active policies and their review status, and Internal Audit shall use this register as an input to its compliance monitoring activities.

8.6.7 Model Governance Compliance

The Bank's Model Risk Management Policy establishes requirements for the development, validation, approval, deployment, monitoring, and retirement of quantitative models used in risk management, credit decisioning, pricing, and regulatory capital calculation. Compliance monitoring shall track adherence to model validation requirements, the status of model findings and remediation actions, the completeness of the model inventory, and the timeliness of model performance reviews. Internal Audit shall provide independent assurance over model governance compliance as described in Section 8.11.

8.6.8 AI Compliance

Emerging regulatory expectations regarding the development and deployment of artificial intelligence systems, including guidance from the FCA on algorithmic decision-making, explainability, and fairness, create new compliance monitoring requirements for the Bank. AI compliance monitoring shall assess adherence to the Bank's AI Governance Policy, the implementation of human oversight requirements, the maintenance of AI system documentation, and the adequacy of bias and fairness monitoring. Internal Audit shall maintain awareness of developments in AI regulation and shall ensure that its AI compliance monitoring programme remains current with evolving regulatory expectations.

8.6.9 Data Protection and Record Retention

The Bank's Record Retention Policy establishes minimum retention periods for all categories of business records, commensurate with regulatory requirements, legal obligations, and operational needs. Compliance monitoring shall assess whether records are being retained for the required periods, whether records are being securely destroyed at the end of their retention period, and whether the record retention schedule remains current with applicable regulatory requirements. Internal Audit shall verify that record retention practices comply with policy on a periodic basis, and shall flag any instances of premature destruction or excessive retention of personal data to the Data Protection Officer.

8.7 Issue Management

8.7.1 Finding Classification

All findings identified during audit engagements shall be classified according to their severity, using the rating scale defined in Section 8.8. The classification assigned to a finding shall reflect the potential impact of the finding on the Bank's risk profile, the likelihood of the risk materialising if the control weakness is not addressed, and the breadth of the population affected. Findings shall be classified consistently and shall not be understated to avoid escalation or to minimise management discomfort. Disagreements between audit and management regarding finding classification shall be resolved by the CAE, whose classification decision shall be final.

8.7.2 Root Cause Analysis

For all findings rated Needs Improvement or above, a thorough root cause analysis shall be conducted as part of the audit engagement to understand the underlying reason for the control failure, rather than merely addressing its surface manifestation. Root cause analysis shall consider contributing factors including: the design of the control; the adequacy of resources and training; the clarity and accessibility of policy guidance; the quality of management oversight; systemic or cultural factors; and technology or data limitations. Root cause analysis findings shall be documented in the audit report and shall inform the scope and requirements of the Management Action Plan.

8.7.3 Management Action Plans

Upon receiving the draft audit report, management of the relevant business unit is required to provide a Management Action Plan (MAP) for each finding. The MAP shall describe the specific remediation actions to be taken to address each finding and its root cause, the individual responsible for each action, and the target completion date. Management Action Plans shall be realistic, specific, and proportionate to the severity of the finding. General commitments to 'review processes' or 'enhance controls' without specific, measurable actions are not acceptable and shall be returned to management for elaboration.

8.7.4 Remediation Tracking

Internal Audit shall maintain a centralised Issue Tracking System recording all open audit findings and their associated Management Action Plans. The status of each open action shall be updated at least monthly by the responsible action owner, and Internal Audit shall review the status and supporting evidence for each action prior to marking it as complete. Actions that are approaching their target date without evidence of meaningful progress shall be escalated in accordance with the escalation framework set out in Section 8.7.8.

8.7.5 Issue Ownership

Each audit finding and associated Management Action Plan shall have a designated owner at an appropriate level of seniority within the relevant business unit. The issue owner is accountable for ensuring that the agreed remediation actions are completed on time and that evidence of completion is provided to Internal Audit. Where a finding spans multiple business units or functions, an overall Issue Owner shall be designated, together with sub-owners for each relevant component. Transfer of issue ownership as a result of organisational restructuring or personnel changes shall be formally documented and notified to Internal Audit.

8.7.6 Target Dates and Extensions

Target completion dates for Management Action Plans shall be set to reflect the complexity of the remediation required, the urgency of the risk, and resource availability. Target dates shall not be extended without the prior written approval of the CAE, except in exceptional circumstances. Requests for extensions shall set out the reasons for the delay, the actions taken to date, and the revised plan for completion. The CAE shall report all extensions to the BAC at the next scheduled meeting, and chronic delay in remediation shall be treated as an independent audit concern.

8.7.7 Verification of Remediation

Upon notification by the issue owner that a Management Action Plan has been completed, Internal Audit shall conduct an independent verification exercise to confirm that the agreed remediation actions have been implemented as described and that the underlying control weakness has been addressed to an acceptable standard. Verification shall be based on documentary evidence and, where appropriate, re-testing of the relevant controls. Internal Audit shall not accept self-certification by management as sufficient evidence of remediation for findings rated Unsatisfactory or Critical. Inadequate or superficial remediation shall result in the finding being re-opened with an escalated target date and additional management accountability.

8.7.8 Closure Process and Escalation

A finding shall be closed only upon confirmation by Internal Audit that the remediation has been satisfactorily completed and that the risk has been reduced to an acceptable level. Closure shall be documented in the Issue Tracking System with the supporting evidence referenced. Findings that remain open beyond their target date shall be subject to the following escalation protocol: findings overdue by more than thirty days shall be escalated to the relevant business unit head; findings overdue by more than sixty days shall be escalated to the relevant Executive Committee member; findings rated Unsatisfactory or Critical that are overdue by more than ninety days shall be reported to the Board Audit Committee as outstanding items requiring Board-level attention.

8.8 Audit Ratings

8.8.1 Rating Scale Overview

Internal Audit applies a standardised rating framework to all audit engagements and individual findings. The purpose of the rating framework is to communicate the relative severity of control deficiencies and the overall quality of the audited entity's control environment in a clear, consistent, and comparable manner. Ratings shall be applied consistently across all engagements and shall not be influenced by management lobbying or relationship considerations. The following ratings are applied to overall audit engagements, and separate finding-level ratings are applied to individual issues.

8.8.2 Satisfactory

A Satisfactory overall audit rating indicates that the internal control environment of the audited entity is adequate and operating effectively. Minor issues may have been identified, but these do not individually or collectively represent a meaningful weakness in the control framework. A Satisfactory-rated entity may have low-rated individual findings requiring management attention, but the overall risk and control profile is acceptable. Satisfactory-rated audits do not require immediate escalation to the BAC beyond the standard reporting cycle.

8.8.3 Needs Improvement

A Needs Improvement rating indicates that one or more control weaknesses have been identified that require management attention and remediation within a defined and monitored timeframe. While the control environment is not fundamentally deficient, the identified weaknesses represent a meaningful risk if not addressed. Needs Improvement-rated audits shall have mandatory Management Action Plans with specific target dates, and progress against remediation shall be monitored by Internal Audit and reported in the CAE's standard reports to the BAC.

8.8.4 Unsatisfactory

An Unsatisfactory rating indicates that significant control weaknesses have been identified that represent a material failure in the control environment, creating elevated risk of financial loss, regulatory breach, operational disruption, or customer harm. Unsatisfactory-rated audits shall be escalated to the BAC and to the relevant Executive Committee member within five business days of the audit report being finalised. An Unsatisfactory rating requires a comprehensive Management Action Plan with enhanced monitoring by Internal Audit and specific milestones for remediation progress.

8.8.5 Critical Finding

A Critical finding is the most severe individual issue rating and is applied where an identified control failure creates an immediate and material risk of significant harm to the Bank, its customers, or the financial system. Critical findings shall be communicated verbally to the CAE immediately upon identification, regardless of whether the relevant audit engagement is complete. Within two business days of confirmation, the CAE shall notify the Board Audit Committee Chair and, where relevant regulatory obligations require it, the appropriate regulatory authority. All Critical findings shall have a mandatory, time-bound management response and an immediate escalation to the relevant Executive Director.

8.8.6 Material Weakness

A Material Weakness is an aggregated assessment applied where a combination of individual findings — even if none is individually Critical — collectively indicate a fundamental deficiency in the Bank's internal control framework over a significant risk area. The identification of a Material Weakness requires the CAE's personal review and sign-off and shall be communicated to the full Board Audit Committee at the next scheduled meeting or, if the next meeting is more than four weeks away, at an extraordinary meeting convened for the purpose. Material Weaknesses shall be reflected in the CAE's Annual Opinion.

8.8.7 Rating Methodology

The determination of audit ratings shall follow a documented, consistent methodology applied by the engagement lead and reviewed by a senior member of Internal Audit prior to issuance of the draft report. The methodology considers: the number and severity of individual findings; the pervasiveness of weaknesses across the audited entity; the potential financial, regulatory, and reputational impact of identified weaknesses; management's demonstrated commitment to and track record on remediation; and the time elapsed since prior findings were identified. Where a finding is borderline between two ratings, the CAE's casting vote shall prevail. The rating rationale shall be documented in the audit working papers and shall be available for review by the BAC and the external quality assessor.

8.9 Reporting Requirements

8.9.1 Audit Reports

The primary output of each audit engagement is the audit report, which presents the engagement objectives, scope, methodology, findings, management responses, and overall rating. Audit reports shall be factually accurate, clearly written, and sufficiently detailed to enable a reader unfamiliar with the audited area to understand the nature, severity, and implications of each finding. Reports shall be drafted in a professional register appropriate for consideration by Senior Management and Board-level audiences. Draft reports shall be circulated to management for factual review within five business days of the exit meeting, and management shall provide their formal response within ten business days. Final reports shall be issued within five business days of receipt of the management response.

8.9.2 Executive Summaries

Each audit report shall be accompanied by an executive summary of no more than two pages, designed to communicate the key messages of the report to time-constrained senior executives. The executive summary shall state the overall audit rating, the number and classification of findings, the most significant risks identified, and the key themes emerging from the engagement. Executive summaries shall be accessible and shall avoid technical jargon where possible.

8.9.3 Board Reporting

The CAE shall present a comprehensive written report to the Board Audit Committee at each scheduled meeting. The BAC report shall include: progress against the Annual Audit Plan; a summary of audit reports issued since the last meeting, including ratings and key findings; the status of open Management Action Plans, including overdue actions; any findings escalated as Unsatisfactory, Critical, or Material Weakness; the status of any special investigations or regulatory preparation activities; and any significant developments in the risk and control environment of which the BAC should be aware.

8.9.4 Regulator Reporting

Internal Audit may be required to report directly to regulators in the context of regulatory examinations, supervisory discussions, or enforcement actions. The form, content, and timing of regulator-facing reporting shall be agreed with the Bank's Legal function and, where appropriate, external legal advisers. All documents prepared for regulatory submission shall be reviewed and approved by the CAE prior to dispatch. Internal Audit shall maintain records of all communications with regulators, including meeting notes, written submissions, and regulator responses.

8.9.5 Escalation Reports

Where a finding requires immediate attention outside the normal reporting cycle, the CAE shall issue an escalation report to the relevant recipients as specified by the finding's classification. Escalation reports shall be concise, clearly identifying the nature and severity of the issue, the potential consequences if not addressed promptly, and the action required of the recipient. Escalation reports shall be acknowledged by the recipient within twenty-four hours and a formal response shall be provided within the timeframe specified in the report.

8.9.6 Exception Reports

Exception reports are periodic communications generated by the Continuous Monitoring Framework that summarise the exceptions identified during the reporting period and the adequacy of management's response. Exception reports shall be reviewed by the Internal Audit function and, where exceptions indicate a systemic control issue, shall be considered as input to audit engagement planning.

8.9.7 Follow-Up Reports

Where a prior audit engagement identified significant findings requiring remediation, a follow-up report shall be issued after the agreed remediation period to document the results of Internal Audit's verification activities. Follow-up reports shall clearly indicate which findings have been satisfactorily remediated, which remain open, and which have been re-opened due to inadequate remediation. Follow-up reports shall be distributed to the same recipients as the original audit report.

8.9.8 Quarterly and Annual Audit Report

A quarterly audit status report shall be issued to the BAC and the Executive Risk Committee summarising Internal Audit's activities and findings for the quarter. An Annual Audit Report shall be issued at the conclusion of each financial year, providing a comprehensive overview of Internal Audit's work, the overall results of audit activities across the Bank's risk universe, trend analysis of audit findings and ratings over the year, the CAE's Annual Opinion on the adequacy and effectiveness of the Bank's risk management, control, and governance processes, and the results of the Internal Audit Quality Assurance Programme.

8.10 Continuous Compliance Framework

8.10.1 Control Testing

The Continuous Compliance Framework supplements periodic audit engagements with ongoing, risk-proportionate testing of key controls across the Bank's control environment. Control testing activities are designed and executed by the Second Line Compliance function, with Internal Audit providing independent oversight and assurance of the adequacy of those testing programmes. Where the results of Second Line control testing indicate systemic weaknesses, Internal Audit shall assess whether additional independent testing is required. Internal Audit may also conduct targeted control testing as a component of its continuous monitoring activities, separate from and in addition to Second Line testing.

8.10.2 Evidence Collection

Effective compliance monitoring requires the systematic collection, retention, and analysis of evidence demonstrating the operation of controls. The Bank shall maintain a comprehensive evidence repository, structured by risk category and control reference, containing documentation supporting the conclusion that key controls are operating effectively. Evidence shall be of sufficient quality, completeness, and contemporaneity to withstand scrutiny in the context of a regulatory examination or audit. Internal Audit shall review the quality and completeness of compliance evidence collections on a periodic basis and shall report deficiencies to the BAC.

8.10.3 Policy Reviews

All internal policies shall be subject to a documented periodic review to ensure that they remain current, accurate, and fit for purpose in light of changes to the regulatory environment, the Bank's business model, and operational experience. The Policy Management function shall maintain a review schedule for all policies and shall escalate any policy that has not been reviewed within the required timeframe to the Policy Governance Committee. Internal Audit shall include a review of policy currency and adequacy in relevant audit engagements and shall independently assess the effectiveness of the policy management process on a periodic basis.

8.10.4 Regulatory Change Monitoring

The regulatory environment in which the Bank operates is subject to continuous evolution. The Compliance function is responsible for maintaining a Regulatory Change Log that records all material regulatory changes, proposed changes, and consultations relevant to the Bank's activities, together with an assessment of their impact and a plan for implementation. Internal Audit shall review the Regulatory Change Log on a quarterly basis to assess the adequacy of the Bank's regulatory change management process and to verify that identified regulatory changes are being implemented within required timeframes.

8.10.5 Training Compliance

The Bank's ability to maintain a compliant and well-governed environment depends on its employees being adequately trained on applicable policies, regulatory requirements, and ethical standards. Training compliance monitoring tracks completion rates for mandatory training programmes across all business units and grades, identifies individuals and areas where training completion is below required levels, and escalates persistent non-compliance to line management and HR. Internal Audit shall assess training compliance rates as a standard element of audit engagements covering compliance-sensitive areas.

8.10.6 Compliance Certifications

Senior management across the Bank's business units are required to complete an annual compliance certification process, in which they attest to their personal adherence to, and their unit's compliance with, applicable laws, regulations, and internal policies. The certification process also requires management to disclose any known or suspected compliance failures or control weaknesses not already reported through other channels. The outputs of the compliance certification process shall be reviewed by the Compliance function and any disclosures shall be

assessed for appropriate follow-up action. Internal Audit shall review the design and adequacy of the compliance certification process on a periodic basis.

8.11 AI Governance Audit

8.11.1 Rationale and Regulatory Context

The Bank's deployment of artificial intelligence and machine learning models in material decision-making processes — including credit assessments, fraud detection, customer segmentation, and pricing — creates specific and evolving governance, ethical, and regulatory obligations. Inadequately governed AI systems can perpetuate or amplify bias, produce unexplainable decisions, breach consumer protection or data protection legislation, and generate significant reputational and regulatory risk. This section sets out the Internal Audit framework for providing independent assurance over the Bank's AI governance arrangements.

8.11.2 AI Explainability

Internal Audit shall assess whether each material AI model deployed by the Bank produces outputs that can be explained, at a level of detail commensurate with the significance of the decision, to the individual or entity affected by that decision. Explainability audits shall examine the technical approach to interpretability adopted by the model development team; the documentation available to support explanation of model outputs to customers, regulators, and management; and the extent to which customer-facing explanations for adverse decisions comply with applicable regulatory requirements under the Consumer Duty framework and data protection legislation. Where a model's outputs cannot be adequately explained, Internal Audit shall treat this as a significant finding requiring urgent management attention.

8.11.3 Bias Monitoring and Fairness Testing

AI models used in credit decisioning, pricing, or customer assessment must be demonstrated to be free from unlawful bias on protected characteristics as defined in applicable equality legislation. Internal Audit shall assess whether the Bank has implemented robust, ongoing bias monitoring for all material AI models, including regular statistical analysis of model outputs disaggregated by relevant demographic characteristics, and whether any identified bias is being promptly investigated and addressed. Fairness testing methodology shall be documented, the rationale for the chosen fairness definition shall be explained and challenged, and the results of fairness testing shall be retained as evidence.

8.11.4 Model Drift

Model drift occurs when the statistical relationship between model inputs and outputs changes over time as a result of changes in the underlying population, economic environment, or data distribution, resulting in model outputs that are less accurate or appropriate than at the time of initial validation. Internal Audit shall assess whether the Bank has implemented adequate model drift monitoring for all material AI models, including defined drift metrics and thresholds, and whether the Bank's response to detected drift — including retraining, recalibration, or retirement of the affected model — is timely and adequate. Models that exhibit significant drift without prompt management intervention shall be treated as a High-rated finding.

8.11.5 Performance Monitoring

Beyond drift, AI models shall be subject to ongoing performance monitoring against the objectives for which they were designed. Internal Audit shall assess the completeness and rigour of performance monitoring frameworks for material AI models, including the KPIs and benchmarks used to assess performance, the frequency of monitoring, and the process for reviewing and acting on performance monitoring outputs. Inadequate performance monitoring frameworks shall be treated as a control weakness, as they prevent timely identification of model degradation.

8.11.6 Retraining Governance

The retraining of AI models — whether on a scheduled basis or in response to identified performance degradation or drift — must be subject to governance arrangements equivalent to those applied at initial model development and validation. Internal Audit shall verify that model retraining events are documented, that retrained models are subject to appropriate validation prior to re-deployment, that the results of retraining are compared against the prior

version to assess improvement, and that model changes are subject to the Bank's Change Management Policy. Retraining events that bypass the validation process shall be treated as a Critical finding.

8.11.7 Model Validation

Independent model validation is a cornerstone of robust model risk management. Internal Audit shall assess whether each material AI model has been independently validated by a team separate from the model development team, whether the scope of validation is commensurate with the model's complexity and materiality, whether validation findings have been tracked to remediation, and whether models are revalidated at appropriate intervals or following material changes. Internal Audit shall not rely solely on the outputs of the model validation function; it shall conduct its own independent assessment of the adequacy of the validation process and the quality of validation documentation.

8.11.8 Independent Review

In addition to the Internal Audit programme described above, material AI models shall be subject to periodic independent review by qualified third parties with relevant expertise. The findings of such independent reviews shall be reported to the Model Risk Committee and to the Board Audit Committee, and Internal Audit shall assess the Bank's response to third-party review findings. The requirement for independent review is in addition to, and does not replace, Internal Audit's own assurance activities.

8.12 Internal Controls Testing

8.12.1 Control Architecture

The Bank's internal control framework comprises a layered architecture of preventive, detective, corrective, and compensating controls, designed and operated across all business processes and risk categories. Effective control testing is essential to providing assurance that this architecture is functioning as intended and that controls are operating with sufficient reliability to reduce residual risk to within the Board-approved risk appetite. Internal Audit's controls testing programme is risk-based and proportionate, focusing the greatest intensity of testing on controls that address the Bank's most significant risks.

8.12.2 Preventive Controls

Preventive controls are designed to stop errors, irregularities, or control failures from occurring in the first place. Examples include authorisation and approval requirements, segregation of duties, access controls, and input validation. Internal Audit shall test the design and operating effectiveness of key preventive controls by reviewing their configuration, testing whether they function as intended in practice, and identifying any circumvention routes or design gaps that may allow errors or misconduct to bypass the control.

8.12.3 Detective Controls

Detective controls are designed to identify errors, irregularities, or control failures after they have occurred, enabling timely correction and investigation. Examples include management reviews, reconciliations, exception reports, and audit logs. Internal Audit shall test detective controls by assessing the frequency and quality of their operation, the adequacy of the follow-up process when exceptions or discrepancies are identified, and the timeliness with which detected issues are escalated and resolved.

8.12.4 Corrective Controls

Corrective controls are designed to remedy identified control failures and restore normal operating conditions. They include incident management processes, error correction procedures, and business continuity plans. Internal Audit shall assess the adequacy of corrective controls by reviewing their design, testing their operation in response to identified failures, and assessing whether corrective actions address root causes rather than merely the immediate symptoms of failure.

8.12.5 Compensating Controls

Compensating controls are implemented where a primary control cannot be applied due to practical constraints, and are designed to achieve an equivalent level of risk mitigation through an alternative mechanism. Internal Audit shall assess whether compensating controls are genuinely effective in mitigating the risk addressed by the absent primary control, and shall verify that compensating controls have been formally approved through the Bank's risk acceptance process. Reliance on compensating controls over an extended period without a plan to implement the primary control shall be treated as a governance concern.

8.12.6 Control Design and Effectiveness

Internal Audit assesses controls across two dimensions: design adequacy and operating effectiveness. A control may be well-designed in concept but fail in practice due to inconsistent application, inadequate resources, or technological failure. Conversely, a control may operate consistently but be poorly designed to address the risk it is intended to mitigate. Both dimensions shall be assessed and reported separately in audit findings, as they require different remediation approaches.

8.12.7 Testing Frequency

The frequency of controls testing shall be calibrated to the risk addressed by the control and the results of prior testing. Controls addressing the Bank's highest risks shall be tested at least annually; controls that were found to

have design or effectiveness weaknesses in a prior testing cycle shall be subject to more frequent testing until the weakness has been remediated and the improvement sustained over at least one full testing cycle. The controls testing schedule shall be documented in the AAP and shall be updated if there is a significant change in the risk profile of the area to which a control relates.

8.12.8 Evidence Requirements

All controls testing shall be supported by adequate, reliable, and documented evidence. The evidence required to support a conclusion that a control is operating effectively will vary by control type but shall as a minimum include: identification of the population from which the test sample was drawn; the size and composition of the sample; the testing procedures applied; the exceptions identified; and the conclusion reached. Working paper documentation shall comply with the standards set out in Section 8.17 of this Chapter. Insufficient evidence is not an acceptable basis for a positive conclusion on control effectiveness; where sufficient evidence cannot be obtained, this shall be treated as a control testing limitation and reported as a finding.

8.13 Regulatory Examinations

8.13.1 Preparation for Regulatory Examinations

Regulatory examinations by the Prudential Regulation Authority, the Financial Conduct Authority, or other applicable regulatory bodies represent a significant event in the Bank's governance calendar and require thorough, coordinated preparation. The Bank's Regulatory Affairs function, in close collaboration with Internal Audit, Legal, Compliance, and the relevant business units, shall maintain a standing regulatory examination preparedness programme. This programme shall include periodic mock examination exercises, maintenance of a regulatory document library, and ongoing tracking of open regulatory findings and commitments.

Prior to a scheduled regulatory examination, the Bank shall prepare a comprehensive examination briefing pack covering the regulatory topics to be assessed, the Bank's current risk profile in those areas, the status of any prior regulatory findings and commitments, and the key personnel to be made available to examiners. Internal Audit shall contribute to the briefing pack by providing a summary of relevant audit findings and the status of management action plans in the areas subject to examination.

8.13.2 Document Requests

Regulatory examiners typically issue formal document requests at the commencement of an examination. The Bank shall respond to all document requests completely, accurately, and within the timescales specified by the regulator. A Regulatory Document Request Register shall be maintained during each examination, tracking each request, the responsible owner for providing the response, the response due date, and the status of the response. Internal Audit shall be available to assist in the preparation of document responses relating to audit activities, audit reports, and issue management.

8.13.3 Regulator Interviews

Regulators may request interviews with members of Internal Audit, including the CAE, as part of an examination. The CAE shall ensure that Internal Audit staff who are required to participate in regulatory interviews are adequately prepared and are fully familiar with the Bank's audit activities and findings in the relevant area. Legal and Compliance shall be notified of all scheduled regulator interviews in advance. The CAE shall brief the BAC Chair promptly following any regulator interview with members of Internal Audit.

8.13.4 Evidence Standards

All evidence provided to regulators must be accurate, complete, and clearly attributed to its source. Documents provided to regulators shall be final, approved versions unless the draft status is specifically noted and explained. Evidence of controls testing shall be sufficiently detailed to enable the examiner to assess the adequacy of the testing methodology without the need for supplementary explanation. Where there is any doubt as to the completeness or accuracy of a document proposed for submission to regulators, the submission shall be reviewed by Legal and Compliance prior to dispatch.

8.13.5 Response Management and Finding Resolution

Following a regulatory examination, the regulator may issue a findings letter, risk reduction programme, or enforcement notice setting out areas of concern and requirements for remediation. The Bank shall provide a formal written response to regulatory findings within the timeframe specified by the regulator, setting out its plans for addressing each finding, including specific remediation actions, responsible owners, and target completion dates. Internal Audit shall provide independent assurance over the implementation of regulatory remediation commitments and shall report the status of regulatory finding remediation to the BAC at each scheduled meeting. Regulatory findings shall be tracked in the Issue Tracking System alongside internally-identified audit findings.

8.14 Quality Assurance Programme

8.14.1 Overview

The Internal Audit Quality Assurance and Improvement Programme (QAIP) is designed to ensure that the Internal Audit function consistently meets the requirements of the Institute of Internal Auditors' International Standards for the Professional Practice of Internal Auditing, the Bank's Internal Audit Charter and Methodology, and applicable regulatory expectations. The QAIP encompasses ongoing monitoring, periodic internal assessments, and regular external quality assessments. The results of the QAIP shall be reported to the BAC and incorporated into continuous improvement plans for the Internal Audit function.

8.14.2 Ongoing Internal QA

Ongoing internal quality monitoring is embedded in the Internal Audit function's standard operating procedures. All audit reports and working papers shall be subject to supervisory review by a senior auditor before issuance, and significant engagements shall be subject to an additional quality review by the CAE or a designated Deputy. A post-engagement review process shall be applied to all engagements, assessing adherence to methodology, the adequacy of evidence, the clarity and accuracy of reporting, and timeliness. The results of post-engagement reviews shall be tracked to identify recurring quality issues requiring systemic remediation.

8.14.3 Peer Review

The Internal Audit function shall participate in periodic peer review arrangements with the internal audit functions of other comparable financial institutions, where such arrangements can be structured without compromising the confidentiality of either institution's audit work. Peer reviews provide an external perspective on the adequacy of Internal Audit's methodology, working paper standards, and reporting quality, and shall be arranged no less frequently than every three years in the periods between formal external quality assessments.

8.14.4 External Quality Assessment

The IIA Standards require that an external quality assessment of the Internal Audit function be conducted by a qualified, independent reviewer at least once every five years. The external assessor shall be approved by the BAC and shall be independent of the Bank and the Internal Audit function. The external quality assessment shall assess conformance with IIA Standards and the Internal Audit Charter, the quality of audit processes and working papers, the adequacy of the QAIP, and the overall effectiveness and value of the Internal Audit function. The results of the external quality assessment and management's response shall be presented to the full Board.

8.14.5 Continuous Improvement

The Internal Audit function shall maintain a Continuous Improvement Plan that documents identified areas for development in methodology, technology, resource capabilities, and reporting, together with specific improvement actions, owners, and target dates. The Continuous Improvement Plan shall be updated at least annually following the completion of the QAIP review cycle and shall be shared with the BAC as part of the CAE's regular reporting.

8.14.6 Training and Professional Development

The Bank is committed to maintaining a high-calibre Internal Audit function through investment in the continuous professional development of its audit staff. All members of the Internal Audit function are required to maintain relevant professional qualifications, including CISA, CIA, ACCA, CISM, or equivalent as appropriate to their role, and to complete a minimum of forty hours of continuing professional development per year. The CAE shall maintain a training and development plan for each member of the function, aligned to the skills requirements of the AAP and the Continuous Improvement Plan.

8.14.7 Audit Methodology Updates

The Internal Audit Methodology shall be reviewed and updated at least annually to ensure that it reflects current IIA Standards, regulatory guidance, best practice in the industry, and the evolving risk environment. Material updates to the Methodology shall be approved by the CAE and notified to the BAC. Training on updated Methodology shall be provided to all relevant Internal Audit staff prior to the effective date of the changes.

8.15 Policy Breach Investigation

8.15.1 Classification of Breaches

Policy breaches are classified according to their severity, taking into account the nature of the policy breached, the potential impact on customers, the Bank, or third parties, the degree of culpability of the individual(s) involved, and whether the breach was isolated or systematic. The following classification framework shall be applied consistently across all policy breach investigations.

8.15.2 Minor Breaches

Minor breaches are isolated, low-impact departures from policy that do not give rise to a risk of significant harm, financial loss, regulatory sanction, or customer detriment. Minor breaches may result from misunderstanding of policy requirements, process failure, or inadvertent error. Minor breaches shall be documented and addressed through management-level coaching and corrective action, with a record maintained by the relevant business unit and reported to Compliance in the monthly compliance reporting cycle.

8.15.3 Material Breaches

Material breaches are departures from policy that have resulted in, or have the potential to result in, meaningful harm to customers, the Bank, or the financial system, or that indicate a systemic failure of controls or culture. Material breaches require a formal investigation, a documented root cause analysis, a Management Action Plan, and a report to the Compliance function. Where a material breach has or may have caused customer harm, appropriate redress obligations shall be assessed and, where applicable, implemented. Internal Audit shall receive notification of all material breaches and shall assess whether they trigger the need for an unplanned audit engagement.

8.15.4 Critical Breaches

Critical breaches are the most severe category and include departures from policy that have resulted in significant financial loss, material regulatory breach, serious customer harm, or damage to the Bank's reputation. Critical breaches require immediate notification to the CAE, the Chief Compliance Officer, the Chief Risk Officer, and the relevant Executive Director. The BAC shall be informed of Critical breaches within forty-eight hours of their identification. Where a Critical breach may constitute a notifiable event under applicable regulatory requirements, the Bank's Legal function shall assess the notification obligation and initiate the notification process without delay.

8.15.5 Employee Investigation

Where a policy breach involves potential employee misconduct, the investigation shall be conducted in accordance with the Bank's Employee Investigation Policy and in close coordination with the Human Resources and Legal functions. Internal Audit may be requested to assist in fact-finding as part of an employee investigation; however, the primary responsibility for employee investigations rests with HR, supported by Legal. Internal Audit's role in such investigations shall be clearly defined at the outset to avoid any compromise of its independence.

8.15.6 Root Cause and Disciplinary Referral

All material and critical breach investigations shall include a documented root cause analysis using a recognised methodology. The root cause analysis shall consider systemic and cultural factors in addition to individual failures. Where the investigation identifies deliberate misconduct, gross negligence, or repeated policy breaches by an individual employee, the matter shall be referred to the Human Resources function for consideration of disciplinary action in accordance with the Bank's Disciplinary Policy. Internal Audit shall have no role in disciplinary decisions but shall track the closure of policy breach investigations and the completion of agreed remediation actions.

8.15.7 Documentation Standards

All policy breach investigations shall be documented in a consistent and comprehensive manner, including: a description of the breach and the circumstances in which it was identified; the scope and methodology of the investigation; the evidence reviewed; the findings of the investigation; the root cause analysis; the remediation actions agreed; and the outcome of any disciplinary process (in general terms, without prejudice to employee privacy). Investigation documentation shall be retained in accordance with the Bank's Record Retention Policy and shall be stored securely with access restricted to those with a legitimate need to review.

8.16 Corrective Action Framework

8.16.1 Corrective and Preventive Action Process

The Corrective and Preventive Action (CAPA) process provides a structured framework for ensuring that identified control failures and compliance gaps are remediated in a timely, thorough, and sustainable manner. The CAPA process applies to all findings arising from Internal Audit engagements, Second Line monitoring activities, regulatory examinations, policy breach investigations, and significant operational events. The process is designed to ensure that remediation addresses not only the immediate manifestation of a failure but its underlying root cause, thereby preventing recurrence.

Each CAPA shall document: the finding or event that triggered the action; the root cause analysis; the specific corrective actions to be taken; the preventive actions to be implemented to reduce the likelihood of recurrence; the owner of each action; the target completion date; and the evidence that will be used to verify completion. CAPAs shall be recorded in the Bank's Issue Tracking System and shall be subject to the same monitoring, escalation, and closure processes as audit findings.

8.16.2 Risk Acceptance

In exceptional circumstances, management may determine that the cost or operational impact of remediating a control weakness is disproportionate to the residual risk it presents, and may elect to formally accept the risk rather than implement the agreed remediation. Risk acceptance is not available as an option for findings rated Critical or for findings that relate to mandatory regulatory requirements. Where risk acceptance is proposed, the relevant management action plan shall document the rationale for acceptance, the mitigating factors considered, and the monitoring arrangements that will be maintained for the duration of the acceptance period. Risk acceptance proposals shall be reviewed and approved by the Chief Risk Officer and shall be notified to the Board Audit Committee.

8.16.3 Issue Escalation and Executive Oversight

The escalation protocol for overdue or inadequately remediated issues is described in Section 8.7.8. In addition to the standard escalation protocol, the CAE shall maintain a formal Executive Issue Escalation process for findings that represent a systemic or strategic control concern, through which the CAE may raise concerns directly with the Chief Executive Officer or the full Executive Committee. The CAE's escalation rights under this process are enshrined in the Internal Audit Charter and cannot be curtailed by any member of management.

8.16.4 Validation Testing and Closure Approval

The closure of any finding rated Unsatisfactory or higher requires specific validation testing by Internal Audit to confirm that the remediation has been implemented as agreed and is operating effectively. Closure of such findings shall be approved by the CAE personally. For findings rated Critical, the CAE shall notify the BAC of the proposed closure and shall provide a summary of the validation testing conducted. Where validation testing identifies that remediation is incomplete or ineffective, the finding shall be re-opened with a revised target date and enhanced escalation requirements.

8.17 Audit Documentation Standards

8.17.1 Working Papers

Working papers are the foundation of every audit engagement and constitute the principal body of evidence supporting audit conclusions, findings, and ratings. All working papers shall be prepared to a standard sufficient to enable an experienced auditor who was not present at the engagement to understand the objectives, scope, procedures performed, evidence reviewed, and conclusions reached. Working papers shall be prepared contemporaneously with the audit work to which they relate and shall not be reconstructed after the fact.

Working papers shall be organised within the Bank's designated audit documentation system in a consistent manner, using the standard engagement file structure prescribed in the Internal Audit Methodology. Each file shall include an engagement planning memorandum, a risk and control matrix, testing workbooks, evidence schedules, a draft and final report, the management response, and a post-engagement quality review record.

8.17.2 Evidence Standards

Evidence used to support audit conclusions shall be sufficient, reliable, relevant, and useful. Sufficiency refers to the quantity of evidence — the sample size and coverage must be adequate to support the conclusions drawn. Reliability refers to the quality and trustworthiness of the evidence source — first-hand observation and system-generated data are more reliable than management representations and informal oral statements. Relevance refers to the connection between the evidence and the control or risk being tested. Usefulness refers to the extent to which the evidence enables meaningful conclusions to be drawn.

8.17.3 Electronic Records

Audit documentation shall be maintained in electronic format in the Bank's designated audit management system, except where original paper documents are required to be retained as evidence. Electronic working papers shall be subject to access controls ensuring that only authorised members of the audit engagement team and designated reviewers can view or edit the documentation. The audit management system shall maintain a version history of all documents, enabling reconstruction of the audit file at any point in time.

8.17.4 Retention

Audit working papers and related documentation shall be retained for a minimum of seven years from the date of the final audit report, or for a longer period where required by applicable regulatory requirements, legal proceedings, or the Bank's Record Retention Policy. Audit documentation that relates to a matter under regulatory investigation or legal proceedings shall not be destroyed without the prior written consent of the Bank's Legal function. At the conclusion of the applicable retention period, audit documentation shall be securely destroyed in accordance with the Bank's data destruction standards.

8.17.5 Version Control

All draft and final audit documents shall be subject to formal version control, with each version clearly labelled with the version number, the date of the version, and the name of the author or reviewer. The final approved version of each audit report shall be clearly identified and distinguished from all draft versions. Working papers shall maintain a clear record of any changes made following supervisory or quality review, with the reason for each change documented.

8.17.6 Confidentiality

Audit documentation, including working papers, draft reports, final reports, and management responses, is classified as Confidential under the Bank's Information Classification Policy. Access shall be restricted to authorised members of the Internal Audit function, the BAC, the relevant business unit management, the external auditors (subject to a reliance agreement), and regulators where required. Audit documentation shall not be shared externally without the prior approval of the CAE and, in the case of sensitive findings, the BAC. Employees handling

audit documentation are reminded that its disclosure outside of authorised channels may constitute a serious disciplinary offence.

8.18 Governance Reporting

8.18.1 Board Reporting

The governance reporting framework ensures that the Board of Directors and its committees receive timely, accurate, and actionable information on the Bank's risk and control environment. Board-level reporting by Internal Audit is described in Section 8.9.3 and is the primary mechanism by which the Board exercises its oversight responsibility over internal audit and compliance matters. Board reports shall be designed to provide a balanced, honest, and clear picture of the control environment, avoiding undue optimism or narrative minimisation of significant findings.

8.18.2 Executive Dashboard

The Executive Dashboard is a monthly management information report presented to the Executive Risk Committee, providing a consolidated view of the Bank's key risk indicators, KPIs, open audit issues, and compliance monitoring metrics. The Executive Dashboard is the primary day-to-day risk management tool for Senior Management and shall provide sufficient granularity to enable management to identify areas requiring immediate attention. Internal Audit contributes to the Executive Dashboard by providing current data on open findings, overdue actions, and the results of ongoing monitoring activities.

8.18.3 Risk, Audit, and Compliance Dashboards

In addition to the Board and Executive reports, the Bank maintains dedicated dashboards for risk management, internal audit, and compliance that provide functional heads and their teams with real-time visibility of metrics and status within their respective domains. The Audit Dashboard provides the CAE and audit team leaders with an up-to-date view of AAP progress, open findings, overdue actions, and monitoring exceptions. The Compliance Dashboard provides the Chief Compliance Officer with a consolidated view of compliance monitoring results, policy breach investigations, and regulatory change management status. The Risk Dashboard provides the Chief Risk Officer with a consolidated view of KRI status, risk appetite utilisation, and significant risk events.

8.18.4 KPI Reporting and Trend Analysis

KPI reporting is embedded in all governance dashboards and committee packs, providing a consistent set of performance metrics enabling assessment of Internal Audit function effectiveness. Key internal audit KPIs include: percentage of AAP completed year-to-date; average cycle time from fieldwork completion to final report; percentage of findings with Management Action Plans completed on time; percentage of overdue findings by rating; and CAE's conformance with IIA Standards. Trend reporting compares current period metrics with prior periods to identify improving or deteriorating trajectories and shall accompany all KPI tables in board and committee reporting.

Policy Supremacy Statement

This Chapter forms part of Stratum Capital Bank's Enterprise Governance & Risk Framework and is to be read in conjunction with all other chapters of that Framework. In the event of any conflict or inconsistency between this Chapter and any other internal policy, standard, or procedure of the Bank, the terms of this Chapter shall prevail to the extent of any inconsistency, unless the conflicting document has been approved at a higher governance level or by a more senior governance body. Matters not addressed in this Chapter shall be resolved by reference to applicable regulatory requirements and, in the absence of specific regulatory guidance, by reference to recognised professional standards including the IIA International Standards for the Professional Practice of Internal Auditing.

Document Control

Version	Date
5.0.0	15 March 2022 – Initial enterprise framework alignment
5.1.0	1 September 2022 – Addition of AI Governance Audit provisions
5.2.0	1 March 2023 – Continuous Compliance Framework expanded
5.3.0	1 September 2023 – Regulatory Examination section restructured
5.4.0	1 June 2024 – Bias monitoring and model drift provisions updated
5.4.1	1 January 2025 – Annual review; Consumer Duty references updated

Cross References

This Chapter should be read in conjunction with the following chapters of the Enterprise Governance & Risk Framework:

- Chapter 1 – Enterprise Governance Framework and Board Charter
- Chapter 2 – Enterprise Risk Management Framework
- Chapter 3 – Credit Risk Policy and Governance
- Chapter 4 – Operational Risk Management Framework
- Chapter 5 – Financial Crime, AML and Sanctions Governance
- Chapter 6 – Technology, Cybersecurity and Data Governance
- Chapter 7 – AI and Model Risk Management Framework

Definitions

Term	Definition
Annual Audit Plan (AAP)	The documented plan of internal audit activities approved by the Board Audit Committee for a given financial year.
Board Audit Committee (BAC)	The committee of the Board of Directors charged with oversight of internal audit, external audit, financial reporting, and compliance.

CAE	Chief Audit Executive – the individual with senior executive responsibility for the Internal Audit function.
CAPA	Corrective and Preventive Action – a structured process for addressing identified failures and preventing recurrence.
CMF	Continuous Monitoring Framework – the Bank's framework for ongoing, automated monitoring of risk indicators and control performance.
Critical Finding	A finding rated at the highest severity level, indicating an immediate and material risk of significant harm.
KPI	Key Performance Indicator – a quantitative metric measuring operational or functional performance against a target.
KRI	Key Risk Indicator – a quantitative metric providing early warning of changes in the risk profile.
MAP	Management Action Plan – the formal remediation plan prepared by management in response to an audit finding.
Material Weakness	An aggregated assessment indicating a fundamental deficiency in the Bank's internal control framework.
Model Drift	Degradation in model performance resulting from changes in the underlying data distribution or population.
QAIP	Quality Assurance and Improvement Programme – the programme ensuring the Internal Audit function meets professional standards.
Three Lines of Defence	The risk governance model comprising the First Line (business units), Second Line (risk and compliance), and Third Line (internal audit).

Appendix References

- Appendix 8A – Internal Audit Charter (separate document)
- Appendix 8B – Annual Audit Plan Template and Risk Scoring Methodology
- Appendix 8C – Audit Report Template
- Appendix 8D – Working Paper Standards and File Structure Guide
- Appendix 8E – Issue Classification and Rating Methodology
- Appendix 8F – Management Action Plan Template
- Appendix 8G – AI Model Audit Checklist
- Appendix 8H – Regulatory Examination Preparedness Protocol
- Appendix 8I – Continuous Monitoring KRI and KPI Register
- Appendix 8J – Quality Assurance Review Template

— End of Chapter 8 —

Stratum Capital Bank | Enterprise Governance & Risk Framework | Chapter 8 | v5.4.1 | Confidential